# Harborlight Incident Report — Technical

2026-10-26 · Prepared by Divine Epie Ngol Esueh · Case HL-INC-2026-0204

## Executive Summary

On 4 February 2026, Harborlight Dental & Insurance suffered a full-domain ransomware compromise consistent with the Akira playbook. A front-office user, Emily.Grant, opened a malicious archive (`Vendor_Invoice_Review.7z`) on workstation BACKOFFICE-PC1. Its payload, `review.dll`, was launched through `rundll32.exe` and established a beacon that was hidden inside `notepad.exe`. The attacker bypassed UAC through a `ms-settings` registry hijack, injected into `spoolsv.exe`, dumped LSASS memory to recover Emily.Grant's cleartext password, and used it to move laterally to the file server HL-FS01 (03:34:09 UTC) and then to the domain controller ADDC01 (04:28:22 UTC).

From the domain controller the attacker dumped the Active Directory database (NTDS.dit) with `ntdsutil`, pushed recovery-destruction commands back down to other hosts over WMI, exfiltrated the contents of `C:\Shares` to a MEGA cloud account using `rclone` disguised as Microsoft Defender (`MsMpEng.exe`), cleared the Security event log on all three hosts, planted three persistence mechanisms, created a new Domain Admin backdoor account (`svc_sql`), and finally encrypted files with the `.akira` extension and dropped 128 ransom notes.

**The incident is not over.** Command-and-control beaconing to `cdn.cloud-endpoint.net` and `sync.cloud-endpoint.net` (fronted by Cloudflare) continued from all three hosts until at least 18:47:29 UTC, well after encryption, and the attacker still holds a Domain Admin account, a full copy of every domain credential hash, and three independent re-entry paths. This must be treated as an active compromise of the entire domain.

Root cause was a combination of control gaps: a user able to mount and execute untrusted ISO/archive content, no application allow-listing, a flat unsegmented network (172.16.0.0/24), reusable cleartext credentials in LSASS memory, and no monitoring of the Sysmon and Security telemetry that recorded every step of the attack.

## Incident Overview and Scope

| Field | Detail |
|---|---|
| Incident ID | HL-INC-2026-0204 |
| Classification | Human-operated ransomware with double extortion (data theft + encryption), Akira tradecraft |
| Date / window | 4 February 2026 (UTC); first beacon activity 02:25, C2 still active at 18:47:29 |
| Detection | Retrospective threat hunt. No alert fired; staff found ransom notes and reported it cold |
| Telemetry | `HarborlightDental_CL` (Sysmon + Windows Security), workspace `LAW-SilentCorridor`, Microsoft Sentinel / KQL |

| Field | Detail |
|---|---|
| Hosts affected | BACKOFFICE-PC1 (workstation), HL-FS01 (file server, 172.16.0.8), ADDC01 (domain controller, 172.16.0.7). All three fully compromised |
| Identities compromised | Emily.Grant (password recovered from LSASS); all domain accounts (NTDS.dit dumped); attacker-created `svc_sql` (Domain Admin) |
| Data impact | Contents of `C:\Shares` exfiltrated to `mega:HARBORLIGHT-exfil`; files encrypted with `.akira` |
| Visibility limits | No PCAP, Zeek or Suricata. Network visibility is Sysmon per-process only |

Scope was established by correlating Sysmon process creation (EID 1), network connections (EID 3), remote thread creation (EID 8), process access (EID 10), file creation (EID 11), registry changes (EID 13) and DNS queries (EID 22) with Windows Security events (4728/4732 group changes, 5379 Credential Manager reads) across all three hosts. All analysis keyed on `EventTime`. `TimeGenerated` reflects ingestion, and `SystemTime` is blank on many rows.

## Attack Timeline

All times UTC, 4 February 2026. Where the telemetry fixes an exact time it is shown. Stages without a pinned timestamp are placed by sequence.

| Time | Stage | Event |
|---|---|---|
| ~02:25 | Initial Access / Execution | Emily.Grant opens `Vendor_Invoice_Review.7z` on BACKOFFICE-PC1. Payload runs as `rundll32.exe D:\review.dll,StartW`. A second, company-branded lure re-runs the same DLL via a drive-letter loop (`for %d in (D E F G H I J)`) and finds it on E:. C2 beaconing begins at 02:25. |
| ~02:25+ | Defense Evasion | Beacon hidden inside `notepad.exe`, a trusted Windows process. |
| 02:42:39 | Privilege Escalation | Second of two UAC-bypass attempts succeeds: `HKCU\Software\Classes\ms-settings\shell\open\command` points to `C:\Users\Public\taskhostw.exe` (masquerading binary). |
| After 02:42 | Defense Evasion | `taskhostw.exe` injects into `spoolsv.exe` via CreateRemoteThread (Sysmon EID 8). Hijacked `spoolsv.exe` performs the rest of the operation, and the pattern recurs on all three hosts. |
| Before 03:34 | Credential Access | `spoolsv.exe` opens `lsass.exe` with `0x1fffff` (PROCESS_ALL_ACCESS). Credentials recovered: `Emily.Grant / Dental2024!`. |
| 03:34:09 | Lateral Movement | BACKOFFICE-PC1 to HL-FS01 (172.16.0.8) using Emily.Grant's credentials. |

| Time | Stage | Event |
|---|---|---|
| 04:04:05 and 04:05:26 | Impact (Anti-Recovery) | HL-FS01 recovery destroyed twice: `vssadmin delete shadows`, `bcdedit recoveryenabled no` + `bootstatuspolicy ignoreallfailures`, `wbadmin delete catalog`. |
| 04:28:22 | Lateral Movement | HL-FS01 to ADDC01 (172.16.0.7). |
| 04:42-04:44 | Lateral Movement (reverse) | Hijacked `spoolsv.exe` on ADDC01 runs `wmic /node:<host> /user:HARBORLIGHT\Emily.Grant ... "cmd /c vssadmin delete shadows /all /quiet"` back to HL-FS01 and BACKOFFICE-PC1. The DC becomes the hub. |
| After 04:28 | Credential Access (DC) | `ntdsutil "ac i ntds" "ifm" "create full C:\Windows\Temp\ntds"`: full NTDS.dit dump. |
| Pre-encryption | Exfiltration | `rclone` renamed `C:\ProgramData\Microsoft\MsMpEng.exe` copies `C:\Shares` to `mega:HARBORLIGHT-exfil` (account `jwilson.vhr@proton.me`). |
| 05:18:21 / 05:19:31 / 05:20 | Defense Evasion | `defender.bat` clears event logs on BACKOFFICE-PC1, HL-FS01 and ADDC01 in turn, about a minute apart. Security log cleared on every host. |
| 05:22:28 / 05:22:57 | Persistence / Priv-Esc | `svc_sql` (password `Summer2024!`) added to local Administrators (4732) and Domain Admins (4728). |
| After 05:22 | Impact (Encryption) | 27 files encrypted with `.akira`. `akira_readme.txt` written 128 times. |
| Through 18:47:29 | Command and Control | About 14,200 beacon connections from all three hosts to Cloudflare-fronted C2 continue long after encryption. |

## Technical Findings by Kill-Chain Stage

### Initial Access and Execution

The intrusion began with a phishing-style lure, `Vendor_Invoice_Review.7z`, opened by Emily.Grant. The archive delivered a disk image that mounted as a drive letter and executed `rundll32.exe D:\review.dll,StartW`, a signed-binary proxy execution (T1218.011). A second file was not new malware. It re-delivered the same `review.dll` with a company-branded lure and a launcher, `cmd.exe /c for %d in (D E F G H I J) do @if exist "%d:\review.dll" rundll32 %d:\review.dll,StartW`, that works regardless of which drive letter the image mounts on (it ran from E:). It was a targeted retry to guarantee the same beacon executed.

### Defense Evasion: Process Injection into Trusted Binaries

The beacon was hidden inside `notepad.exe` to blend in with a legitimate, trusted process before anyone was looking. After elevation, the attacker's masquerading binary `C:\Users\Public\taskhostw.exe` injected into `spoolsv.exe` via CreateRemoteThread (Sysmon EID 8, T1055). From that point, `spoolsv.exe`, the Print Spooler, carried out credential theft, lateral movement and impact

actions on every host. Filtering on process name alone would have missed this. Filtering on the parent/child relationship (`spoolsv.exe` spawning `cmd.exe`, `wmic.exe` or `ntdsutil.exe`) exposes it immediately.

### Privilege Escalation: UAC Bypass

The attacker wrote `HKCU\Software\Classes\ms-settings\shell\open\command` to point at `C:\Users\Public\taskhostw.exe` (T1548.002). When an auto-elevating Windows binary reads that key, it launches the attacker's binary at high integrity without a UAC prompt. Two attempts were made and only the **second, at 02:42:39**, elevated. The legitimate `taskhostw.exe` always runs from `C:\Windows\System32\`, while the attacker copy ran from the user-writable `C:\Users\Public\`. The discriminator is the full `Image` path, not the filename (T1036.005).

### Credential Access: LSASS

Hijacked `spoolsv.exe` opened `lsass.exe` with access mask `0x1fffff` (PROCESS_ALL_ACCESS), which is full read access to LSASS memory and enough to dump credentials (T1003.001). The recovered credential was **Emily.Grant / Dental2024!**. Windows Credential Manager reads (EventCode 5379) in the same window were assessed as **noise**: routine, user-context activity unrelated to the theft.

### Lateral Movement: Hub-and-Spoke

Emily.Grant's credential, valid but out of baseline for any host beyond her own workstation, was used to reach HL-FS01 (172.16.0.8) at **03:34:09** and ADDC01 (172.16.0.7) at **04:28:22** (T1078, T1021.002). Movement was not one-way. Between 04:42 and 04:44, hijacked `spoolsv.exe` on ADDC01 ran `wmic /node:<host> /user:HARBORLIGHT\Emily.Grant /password:Dental2024! process call create "cmd /c vssadmin delete shadows /all /quiet"` back against HL-FS01 and BACKOFFICE-PC1 (T1047). The domain controller became a command hub pushing actions down to hosts that were already owned. On a flat /24 with no segmentation, nothing constrained this movement.

### Credential Access (again): NTDS.dit

On the DC the attacker ran `ntdsutil "ac i ntds" "ifm" "create full C:\Windows\Temp\ntds"`, an Install-From-Media dump that copies NTDS.dit and the SYSTEM hive (T1003.003). Every domain account's password hash must be considered compromised.

### Defense Evasion (again): Log Clearing

`defender.bat` cleared event logs on all three hosts, staggered about a minute apart: BACKOFFICE-PC1 (05:18:21), HL-FS01 (05:19:31), ADDC01 (05:20) (T1070.001). The **Security** channel was the one channel cleared on every host without exception. Because Sysmon telemetry had already been forwarded to the workspace, the on-host wipe did not remove the evidence used in this investigation.

### Exfiltration

`rclone`, renamed to `C:\ProgramData\Microsoft\MsMpEng.exe` to impersonate the Microsoft Defender engine (T1036.005), copied `C:\Shares` to the remote `mega:HARBORLIGHT-exfil` (T1567.002). The receiving MEGA account is registered to **jwilson.vhr@proton.me**. Theft of data ahead of encryption is the standard double-extortion sequence.

### Impact: Inhibit System Recovery

HL-FS01 received the full anti-recovery treatment, twice (04:04:05 and 04:05:26): shadow-copy deletion via `vssadmin` and `wmic`, `bcdedit /set recoveryenabled no` with `bootstatuspolicy ignoreallfailures`, and `wbadmin delete catalog` (T1490). ADDC01 received only partial treatment (`vssadmin delete shadows /all /quiet`, no `bcdedit` or `wbadmin`), so some recovery options may survive on the DC.

### Persistence and Command and Control

Three independent re-entry paths were established (T1547, T1543): the original `taskhostw.exe` implant, `C:\Users\Public\OneDriveSync.exe`, and `wsync.exe` (spawned from `taskhostw.exe`) on HL-FS01. The implants beaconed to `cdn.cloud-endpoint.net` and `sync.cloud-endpoint.net`. Sysmon DNS events (EID 22) show both names resolving to the same shared Cloudflare addresses (104.21.30.237, 172.67.174.46), so the real C2 server is hidden behind a CDN (T1090.004, T1071.001). The channel was persistent, with about 14,200 connections from all three hosts between 02:25 and 18:47 (about 4,264 on port 80 and 9,954 on port 443). **Callbacks were still occurring at 18:47:29Z, so the incident is ongoing.**

### Persistence / Privilege Escalation (again): Domain Backdoor

The attacker created `svc_sql` (password `Summer2024!`) (T1136.002). `net localgroup Administrators svc_sql /add` succeeded (EventCode 4732, 05:22:28) and `Add-ADGroupMember -Identity "Domain Admins" -Members svc_sql` succeeded (EventCode 4728, 05:22:57) (T1098). Two earlier `net group "Domain Admins"` attempts produced no group-change event and therefore failed. A second name, `akira_svc`, appeared only in a `net user akira_svc /domain` lookup. There is no 4720 creation or group-add event, so **akira_svc does not exist**, and analysts should not waste remediation effort on it.

### Impact: Encryption

27 files were encrypted with the `.akira` extension, confirmed by Sysmon file-creation events (EID 11), and the ransom note `akira_readme.txt` was written 128 times across the shares (T1486).

## MITRE ATT&CK Mapping

| Technique | Name | Tactic |
|---|---|---|
| T1566 | Phishing (malicious archive lure) | Initial Access |
| T1218.011 | System Binary Proxy Execution: Rundll32 | Execution / Defense Evasion |
| T1027 | Obfuscated Files or Information (archive/ISO packaging) | Defense Evasion |
| T1055 | Process Injection (notepad.exe, spoolsv.exe) | Defense Evasion / Priv-Esc |
| T1548.002 | Abuse Elevation Control: Bypass UAC | Privilege Escalation |

| Technique | Name | Tactic |
|---|---|---|
| T1036 / T1036.005 | Masquerading: Match Legitimate Name (taskhostw.exe, MsMpEng.exe) | Defense Evasion |
| T1555 | Credentials from Password Stores (Credential Manager reads, assessed as noise) | Credential Access |
| T1003.001 | OS Credential Dumping: LSASS Memory | Credential Access |
| T1003.003 | OS Credential Dumping: NTDS | Credential Access |
| T1078 | Valid Accounts | Lateral Movement / Persistence |
| T1021.002 | Remote Services: SMB/Windows Admin Shares | Lateral Movement |
| T1047 | Windows Management Instrumentation | Execution / Lateral Movement |
| T1070.001 | Indicator Removal: Clear Windows Event Logs | Defense Evasion |
| T1567.002 | Exfiltration to Cloud Storage | Exfiltration |
| T1490 | Inhibit System Recovery | Impact |
| T1547 / T1543 | Boot or Logon Autostart / Create or Modify System Process | Persistence |
| T1090.004 / T1071.001 | Proxy: Domain Fronting / Web Protocols | Command and Control |
| T1136.002 | Create Account: Domain Account | Persistence |
| T1098 | Account Manipulation | Persistence / Priv-Esc |
| T1486 | Data Encrypted for Impact | Impact |

## Indicators of Compromise

| Type | Indicator | Context |
|---|---|---|
| File | `Vendor_Invoice_Review.7z` | Initial lure opened by Emily.Grant |
| File | `review.dll` (export `StartW`) | Payload executed via rundll32 from mounted image (D:, E:) |
| File | `C:\Users\Public\taskhostw.exe` | Masquerading implant / UAC-bypass target |
| File | `C:\Users\Public\OneDriveSync.exe` | Persistence implant |
| File | `wsync.exe` (HL-FS01) | Persistence implant |
| File | `C:\ProgramData\Microsoft\MsMpEng.exe` | Renamed rclone (exfiltration tool) |

| Type | Indicator | Context |
|---|---|---|
| File | `defender.bat` | Log-clearing script |
| File | `akira_readme.txt`, `*.akira` | Ransom note (128) / encrypted files (27) |
| Registry | `HKCU\Software\Classes\ms-settings\shell\open\command` | UAC bypass |
| Domain | `cdn.cloud-endpoint.net`, `sync.cloud-endpoint.net` | C2 (Cloudflare-fronted) |
| IP | 104.21.30.237, 172.67.174.46 | Shared Cloudflare addresses for C2 |
| Cloud | `mega:HARBORLIGHT-exfil`, `jwilson.vhr@proton.me` | Exfiltration destination / account |
| Account | Emily.Grant | Compromised user (password recovered from LSASS) |
| Account | `svc_sql` | Attacker-created Domain Admin |
| Path | `C:\Windows\Temp\ntds` | NTDS.dit IFM dump output |

These values come from a simulated training environment. In a live environment each should be swept across EDR, SIEM, DNS and firewall history for reuse.

## Evidence and Verification Queries

All analysis was performed in KQL against `HarborlightDental_CL` in workspace `LAW-SilentCorridor`. Representative queries:

```
// UAC bypass: registry write to the ms-settings handler
HarborlightDental_CL
| where EventID == 13 and TargetObject has "ms-settings\\shell\\open\\command"
| project EventTime, host, Image, TargetObject
| order by EventTime asc

// Real or noise: taskhostw.exe outside System32
HarborlightDental_CL
| where EventID == 1 and Image endswith "taskhostw.exe"
| summarize count() by Image, host

// Injection and LSASS access by spoolsv.exe
HarborlightDental_CL
| where EventID in (8, 10) and SourceImage endswith "spoolsv.exe"
| project EventTime, host, EventID, SourceImage, TargetImage, GrantedAccess

// Commands executed by the hijacked Print Spooler
HarborlightDental_CL
| where EventID == 1 and ParentImage endswith "spoolsv.exe"
| project EventTime, host, Image, CommandLine
| order by EventTime asc

// C2 resolution and beacon volume by port
HarborlightDental_CL
```

```
| where EventID == 22 and QueryName has "cloud-endpoint.net"
| distinct QueryName, QueryResults

HarborlightDental_CL
| where EventID == 3 and DestinationIp in ("104.21.30.237", "172.67.174.46")
| summarize count(), min(EventTime), max(EventTime) by DestinationPort

// Domain backdoor: group changes that actually succeeded
HarborlightDental_CL
| where EventCode in (4728, 4732)
| project EventTime, host, EventCode, EventData_Xml
```

## Noise and False-Positive Analysis

- **Credential Manager reads (EventCode 5379)** look like credential theft but are routine user-context activity. The actual theft is the `0x1fffff` LSASS handle from `spoolsv.exe`.
- **`taskhostw.exe`** is a legitimate Windows binary. Only the copy running from `C:\Users\Public\` is malicious. Filter on `Image`, not the filename.
- **`MsMpEng.exe`** is normally the Defender engine. The copy in `C:\ProgramData\Microsoft\` with rclone arguments is the exfiltration tool.
- **`spoolsv.exe`** is a legitimate service, but it never spawns `wmic`, `ntdsutil` or `vssadmin` in a healthy estate.
- **`akira_svc`** appears in a lookup only. No 4720 or group-add event, so no account exists.
- **Coastal MSP tooling.** The MSP holds the only legitimate Domain Admin credentials, and none of the privileged activity on HL-FS01 or ADDC01 traces to an MSP admin session.

## Telemetry Gaps and Limitations

There is no packet capture, Zeek or Suricata, so payload contents of the C2 and exfiltration traffic cannot be inspected, and the volume of data copied to MEGA cannot be measured from this dataset. Network visibility is limited to Sysmon per-process connection and DNS events. The on-host Security logs were cleared, so analysis depends on events already forwarded before 05:18. `SystemTime` is unreliable, so `EventTime` was used throughout.

## Recommendations

**Immediate containment** (the attacker is still active):

1. Isolate all three hosts from the network and block `cloud-endpoint.net` at DNS and the egress firewall.
2. Disable `svc_sql` and remove it from Domain Admins and local Administrators. Disable Emily.Grant and reset her password.
3. Because NTDS.dit was dumped, reset **every** domain account password and reset the `krbtgt` account twice, with replication in between.
4. Remove `taskhostw.exe`, `OneDriveSync.exe` and `wsync.exe` and their autostart entries, plus the `ms-settings` registry hijack.

5. Report the MEGA account and `jwilson.vhr@proton.me` to the provider. Begin breach-notification assessment for the exfiltrated share data (patient and insurance records may be in scope).

**Eradication and recovery:**

1. Rebuild all three hosts from known-good media. Do not attempt to clean them in place.
2. Restore from offline or immutable backups. HL-FS01's on-host recovery is destroyed, and ADDC01 may retain partial shadow copies.

**Structural hardening:**

1. Segment the network so workstations cannot reach the DC or file server over SMB/WMI except from defined admin hosts.
2. Enable LSA Protection (RunAsPPL) and Credential Guard to block LSASS dumping.
3. Block ISO/IMG auto-mount and `.7z` attachments at the mail gateway, and apply application allow-listing to block execution from `C:\Users\Public\` and `C:\ProgramData\`.
4. Disable the Print Spooler on the domain controller and file server.
5. Forward Security and Sysmon logs to a monitored SIEM with alerts on 1102/104 log clears, 4728/4732 privileged-group changes, LSASS access with `0x1fffff`, and `vssadmin`/`bcdedit`/`wbadmin` usage.

## Lessons Learned

1. **Stopping the loud part is not the end.** Encryption is the visible finale, but beaconing continued for over 13 hours afterwards. Always confirm the end of an incident in the data.
2. **Names lie, paths and lineage do not.** `taskhostw.exe`, `MsMpEng.exe` and `spoolsv.exe` were all real Windows names. The full image path and parent process exposed every one.
3. **A flat network turns one password into the whole domain.** One workstation credential reached the DC in two hops, and the DC then pushed commands back to every host.
4. **Logging without monitoring is just evidence for later.** Every step was recorded in Sysmon and Security logs that nobody reviewed until after the ransom notes appeared.